

ЗАТВЕРДЖЕНО
Наказом ТОВ "Криптографічні Телесистеми"
від ____ 2026 р. № ____
(в редакції наказу ТОВ "Криптографічні Телесистеми"
від ____ 2026 р. № ____)

Телекомунікаційна система ERP/1
«Повний набір сервісів»

ЦІЛЬОВИЙ ПРОФІЛЬ БЕЗПЕКИ

UA.46207985.C3I.ЦПБ-99

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
1. УПРАВЛІННЯ ДОСТУПОМ (АС) (АС)				
1	Управління обліковими записами	Система забезпечує створення, активацію, зміну та видалення облікових записів відповідно до політик організації. Права доступу жорстко прив'язані до ідентифікатора працівника ('subject_employee') або ролі.	АС-2	Параметр: account_management Тип: boolean Значення: true
2	Примусове застосування доступу (Access Enforcement)	Усі запити до ресурсів системи примусово проходять через Policy Decision Point (PDP) модуля 'abac'. Прямий доступ до даних в обхід механізмів авторизації заборонено архітектурно.	АС-3	Параметр: access_enforcement Тип: boolean Значення: true
3	Принцип найменших привілеїв (Least Privilege)	Профілі безпеки і ролі конфігуруються таким чином, що користувачам надаються лише ті привілеї, які необхідні для виконання їхніх посадових обов'язків. Механізм дозволів 'abac' працює за принципом 'Default-Deny'.	АС-6	Параметр: least_privilege Тип: boolean Значення: true
4	Блокування сеансу	Сеанс користувача автоматично блокується системою ('sync/n2o' session expiry) після визначеного періоду бездіяльності, вимагаючи повторної автентифікації.	АС-11	Параметр: session_lock_timeout Тип: integer Значення: 900
5	Завершення сеансу	Користувач може ініціювати завершення сеансу (logout). Крім того, система примусово завершує сеанси при досягненні максимального часу життя токена або зміни контексту безпеки.	АС-12	Параметр: session_termination Тип: boolean Значення: true
6	Дозволені дії без ідентифікації чи автентифікації	Система явно визначає перелік відкритих сторінок та API-ендпойнтів (наприклад, портал входу або публічний довідник), доступних без автентифікації. Будь-які інші дії суворо заборонені.	АС-14	Параметр: permitted_unauthenticated_actions Тип: boolean Значення: true
7	Віддалений доступ	Віддалений доступ до системи керується додатковими політиками (наприклад, перевірка IP-адреси, VPN, mTLS), які інтегруються з 'sync/ca' та 'abac' для забезпечення безпеки доступу за межами захищеного периметра.	АС-17	Параметр: remote_access_control Тип: boolean Значення: true
8	Динамічне пов'язання атрибутів (заборона кешування)	ABAC через компонент PIP (Policy Information Point) динамічно завантажує актуальні атрибути з контексту (наприклад, стан об'єкта 'object_process' чи профіль 'subject_employee' з KVS) безпосередньо в момент виконання запиту ('request'). Це гарантує, що рішення приймається на базі поточного, а не закешованого стану безпеки.	АС-16(1)	Параметр: dynamic_binding Тип: boolean Значення: true
9	Зміна значень атрибутів авторизованими особами через PAP	Точка адміністрування PAP дозволяє уповноваженим адміністраторам (які пройшли перевірку PDP) змінювати правила ('rule'), політики ('policy') та кадрові атрибути співробітників, гарантуючи, що лише особи з належними повноваженнями можуть керувати системою доступу.	АС-16(2)	Параметр: authorized_changes Тип: boolean Значення: true
10	Підтримка системою пов'язання атрибутів (KVS)	Інфраструктура бази даних 'sync/kvs' нативно інтегрована з моделями 'abac.hrl'. Система зберігає зв'язки між суб'єктами та атрибутами на рівні записів (records), що не підлягають несанкціонованому перезапису.	АС-16(3)	Параметр: attribute_binding_support Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
11	Пов'язання атрибутів авторизованими особами	Тільки уповноважені особи (з відповідними атрибутами безпеки) можуть створювати або делегувати повноваження (наприклад, призначати ролі 'assistant' або 'delegate' в моделі 'subject_employee').	AC-16(4)	Параметр: binding_by_authorized_individuals Тип: boolean Значення: true
12	Відображення атрибутів на пристроях виведення (nitro)	Завдяки інтеграції з 'sync/nitro', рівні конфіденційності та безпекові атрибути об'єктів чітко рендеряться на інтерфейсі клієнта (веб-сторінках) у вигляді візуальних міток.	AC-16(5)	Параметр: display_attributes Тип: boolean Значення: true
13	Підтримка пов'язання атрибутів організацією (org, branch)	В 'subject_employee' підтримуються специфічні атрибути для ієрархічної структури (поля 'org', 'branch'), що дозволяє обчислювати доступ на основі приналежності до організаційної одиниці.	AC-16(6)	Параметр: org_binding_support Тип: boolean Значення: true
14	Послідовна інтерпретація атрибутів (XACML algorithms)	Використання стандартизованих алгоритмів комбінування політик XACML (алгоритми 'all' або 'any') у PDP гарантує строгу та несуперечливу математичну інтерпретацію безпекових обмежень по всій системі.	AC-16(7)	Параметр: consistent_interpretation Тип: boolean Значення: true
15	Техніки та технології пов'язання атрибутів (Pattern Matching, CA)	Механізми Pattern Matching платформи Erlang/OTP використовуються для швидкого та безпомилкового порівняння атрибутів. Інтеграція криптографічних підписів ('sync/ca') у структуру об'єкта підтверджує автентичність його міток.	AC-16(8)	Параметр: binding_techniques Тип: boolean Значення: true
16	Перепризначення атрибутів згідно з життєвим циклом	Політики можуть передбачати логіку перепризначення атрибутів у процесі життєвого циклу об'єкта (наприклад, після підписання документа його атрибут статусу змінюється, що автоматично змінює правила доступу до нього).	AC-16(9)	Параметр: attribute_reassignment Тип: boolean Значення: true
17	Конфігурація атрибутів уповноваженими особами (RAP API)	Інфраструктура RAP надає API для гнучкого налаштування нових типів атрибутів і політик, гарантуючи, що ці налаштування виконуються тільки згідно встановлених процедур адміністрування.	AC-16(10)	Параметр: authorized_configuration Тип: boolean Значення: true
18	Атрибути безпеки об'єкту	ВРЕ перед будь-яким переходом до наступного кроку ('bre:next') аналізує атрибути (метадані, документи), прив'язані до процесу. Шлюзи перевіряють ці мітки для ухвалення рішень маршрутизації.	AC-4(1)	Параметр: object_security_attributes Тип: boolean Значення: true
19	Домени обробки (ізолювані процеси Erlang)	Кожен BPMN-процес виконується як окремий ізолюваний процес віртуальної машини Erlang (Actor). Ці процеси створюють незалежні безпекові домени обробки інформації без спільної пам'яті.	AC-4(2)	Параметр: processing_domains Тип: boolean Значення: true
20	Управління інформаційним потоком (SequenceFlow)	Сутність 'sequenceFlow' (ребра графу BPMN) математично обмежує єдині можливі шляхи передачі інформації між задачами.	AC-4(3)	Параметр: enforce_sequence_flow Тип: boolean Значення: true
21	Управління потоком зашифрованої інформації	ВРЕ здатний маршрутизувати зашифровані payload-дані як непрозорі (opaque) структури, залишаючи розшифрування авторизованим клієнтам або конкретним сервісним завданням ('serviceTask').	AC-4(4)	Параметр: encrypted_payloads Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
22	Вбудовування типів даних (Erlang Records)	Об'єкти інформаційного потоку строго типізовані через структури 'record' (наприклад, '#userTask{ }', '#messageEvent{ }'). Це запобігає переміщенню невідомих форматів.	AC-4(5)	Параметр: embedded_data_types Тип: boolean Значення: true
23	Метадані (список docs у BPE)	BPE керує метаданими документів, використовуючи внутрішній список 'docs' (API 'bpe:docs/1', 'bpe:amend/2'), що невіддільно супроводжує потік процесу.	AC-4(6)	Параметр: metadata_management Тип: boolean Значення: true
24	Механізми одностороннього потоку (DAG)	Направлені ациклічні графи (DAG) BPMN природно реалізують односторонню передачу даних від 'beginEvent' до 'endEvent' без можливості повернення (якщо це не передбачено схемою).	AC-4(7)	Параметр: one_way_flow Тип: boolean Значення: true
25	Політики безпеки (Gateways)	Логічні шлюзи ('gateway') виступають інтегрованими фільтрами, які застосовують політики безпеки на розгалуженнях потоку.	AC-4(8)	Параметр: security_policies Тип: boolean Значення: true
26	Перевірки, що проводить персонал (UserTask)	Використання '#userTask{ }' зупиняє автоматичний потік інформації та вимагає ручної перевірки (Human-in-the-loop) і підтвердження для продовження маршруту.	AC-4(9)	Параметр: personnel_checks Тип: boolean Значення: true
27	Активізація та деактивізація фільтрів політики (BoundaryEvent)	Використання подій, як-от 'boundaryEvent' (Boundary Events), дозволяє динамічно активувати обхідні гілки політик в залежності від виникнення інцидентів або таймаутів.	AC-4(10)	Параметр: filter_activation Тип: boolean Значення: true
28	Конфігурація фільтрів політики безпеки (XML)	Правила маршрутизації (фільтри) завантажуються декларативно з BPMN XML файлів та транслуються у незмінні правила Erlang ('bpe:load/1').	AC-4(11)	Параметр: filter_configuration Тип: boolean Значення: true
29	Ідентифікатори типу даних (MessageEvent)	Система розрізняє вхідні повідомлення через обробку 'messageEvent' з відповідними ідентифікаторами повідомлень, ігноруючи нерозпізнані сигнали.	AC-4(12)	Параметр: data_type_identifiers Тип: boolean Значення: true
30	Декомпозиція на субкомпоненти (Call Activity)	BPE підтримує виклик підпроцесів ('Call Activity'), що дозволяє розбити складні потоки на ізольовані субкомпоненти зі своїми власними політиками.	AC-4(13)	Параметр: subcomponent_decomposition Тип: boolean Значення: true
31	Обмеження фільтра політики (conditions)	Можливості маршрутизації обмежені набором умов 'condition()', які дозволяють математично гарантувати неперетин потоків.	AC-4(14)	Параметр: policy_filter_constraints Тип: boolean Значення: true
32	Виявлення несанкціонованої інформації	При спробі передати процесу повідомлення, яке не відповідає поточній стадії потоку (unauthorized message), система автоматично відкидає його або фіксує в лог як невалідний event.	AC-4(15)	Параметр: unauthorized_info_detection Тип: boolean Значення: true
33	Передача інформації про взаємопов'язані системи (ServiceTask)	Компонент '#serviceTask{ }' дозволяє інтегрувати механізми перевірки даних, перш ніж передати інформаційний потік до інших ІТС (наприклад, через API REST або RPC).	AC-4(16)	Параметр: interconnected_systems_transfer Тип: boolean Значення: true
34	Прив'язка атрибуту безпеки (Process ID)	Інформація в рамках потоку жорстко прив'язується до Process ID (Id інстанції). Усі документи успадковують обмеження доступу поточного процесу.	AC-4(18)	Параметр: security_attribute_binding Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
35	Перевірка метаданих (BPMN compare)	BPMN-умови підтримують функції типу '{compare, Field, ConstCheckAgainst}', що перевіряють значення конкретних метаданих об'єкта під час прийняття рішення про маршрут.	AC-4(19)	Параметр: metadata_validation Тип: boolean Значення: true
36	Затверджені рішення (Default-Deny)	Erlang Match Specifications та XACML гарантують, що лише явно затверджені алгоритми маршрутизації виконуються (Default-Deny принцип).	AC-4(20)	Параметр: approved_decisions Тип: boolean Значення: true
37	Фізичне та логічне відділення інформаційних потоків	Логічне відділення гарантується механізмом процесів OTP VM. Можливість виконання різних процесів на різних фізичних нодах Erlang-кластера забезпечує фізичне відділення потоків.	AC-4(21)	Параметр: physical_logical_separation Тип: boolean Значення: true
38	Єдиний доступ (bre:next)	Централізований компонент контролю 'bre:next' слугує єдиною точкою (Choke Point) доступу та маршрутизації для всіх інформаційних потоків.	AC-4(22)	Параметр: single_access_point Тип: boolean Значення: true
39	Модифікована інформація, яка не підлягає оприлюдненню (scrubbing)	При поверненні історії та статусів через API клієнту, BPE може відфільтрувати та очищати внутрішні атрибути ('scrubbing'), не допускаючи витоку чутливої інформації.	AC-4(23)	Параметр: scrub_hidden_fields Тип: boolean Значення: true
40	Нормалізований формат (BPE Record)	Весь внутрішній потік конвертується в уніфікований стандартизований формат ('BPE Record Format'), незалежно від того, як дані надійшли на вхід.	AC-4(24)	Параметр: normalized_format Тип: boolean Значення: true
41	Очищення даних (Garbage Collection, End Event)	Вбудовані механізми Garbage Collection віртуальної машини Erlang та знищення об'єктів пам'яті ізольованого процесу після завершення ('End Event') забезпечують очищення даних з ОЗУ.	AC-4(25)	Параметр: data_sanitization Тип: boolean Значення: true
42	Дії з фільтрації аудиту (hist у KVS)	Кожний крок і зміна маршруту фіксується у вигляді об'єкта 'hist' у 'kvs', створюючи прозорий ланцюг подій, де шлюзи та фільтри залишають свій слід.	AC-4(26)	Параметр: audit_filter_actions Тип: boolean Значення: true
43	Незалежні фільтруючі механізми (ABAC + BPE)	Дозвіл на доступ (ABAC) та перевірка логіки процесу (BPE) працюють як архітектурно незалежні механізми, підсилюючи концепцію "Defense-in-depth".	AC-4(27)	Параметр: independent_filtering Тип: boolean Значення: true
44	Лінійні фільтрувальні канали (Linear Pipeline)	BPE підтримує лінійну маршрутизацію (Linear Pipeline), коли 'SequenceFlow' гарантовано не має відгалужень, забезпечуючи послідовне виконання політик без ризику обходу.	AC-4(28)	Параметр: linear_pipelines Тип: boolean Значення: true
45	Механізми оркестровки	Ядро BPE виступає єдиним централізованим механізмом оркестровки інформаційного обміну в рамках системи.	AC-4(29)	Параметр: orchestration_mechanisms Тип: boolean Значення: true
46	Фільтрація з використанням кількох процесів (Parallel Gateway)	Компонент 'Parallel Gateway' ('#gateway{type=parallel}') створює декілька паралельних потоків, кожен з яких може мати власні незалежні правила фільтрації.	AC-4(30)	Параметр: multi_process_filtering Тип: boolean Значення: true
47	Запобігання передачі вмісту	Якщо інформаційний об'єкт не відповідає політиці (фільтр на Gateway відхилив вміст), процес переривається або спрямовується на подію помилки (Error Event).	AC-4(31)	Параметр: content_transfer_prevention Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
48	Вимоги до процесу передачі інформації (Receive/Send Task)	Механізми 'Receive Task' та 'Send Task' строго декларують вимоги до структури payload-повідомлень перед тим, як дозволити зовнішній чи внутрішній обмін.	AC-4(32)	Параметр: transfer_process_requirements Тип: boolean Значення: true
2. ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ (IA) (IA)				
49	Ідентифікація та автентифікація (організаційні користувачі)	Система однозначно ідентифікує та автентифікує (перевіряє справжність) організаційних користувачів та процеси, що діють від їх імені, перед тим, як дозволити їм доступ до захищених ресурсів.	IA-2	Параметр: org_user_auth Тип: boolean Значення: true
50	Ідентифікація та автентифікація (неорганізаційні користувачі)	Зовнішні користувачі, що підключаються з публічних мереж, проходять сувору автентифікацію (наприклад, за допомогою mTLS або інтеграції з КЕП) для запобігання анонімому або підробленому доступу.	IA-8	Параметр: non_org_user_auth Тип: boolean Значення: true
51	Автентифікація на основі пароля (хешування)	Для паролів чи PING-кодів (наприклад, для розблокування контейнерів PKCS#12) використовуються криптостійкі функції хешування з сіллю для запобігання атакам.	IA-5(1)	Параметр: password_based_auth Тип: boolean Значення: true
52	Автентифікація на основі відкритого ключа	Є основним профілем бібліотеки 'ca'. Вона генерує, перевіряє (validate) та керує життєвим циклом інфраструктури відкритих ключів (X.509), забезпечуючи строго автентифікацію.	IA-5(2)	Параметр: pki_enabled Тип: boolean Значення: true
53	Зміна автентифікаторів до доставки (CSR)	Система підтримує протоколи, за яких приватний ключ генерується на пристрої клієнта, а до CA відправляється лише Certificate Signing Request (CSR). Це гарантує зміну/встановлення ключів ще до факту доставки готового сертифіката користувачу.	IA-5(5)	Параметр: pre_delivery_change Тип: boolean Значення: true
54	Захист автентифікаторів (PEM/PKCS#12)	Приватні ключі (автентифікатори) зберігаються в захищеному зашифрованому вигляді (наприклад, контейнери формату PEM з паролем або PKCS#12), що унеможлиблює використання ключів без знання пароля доступу.	IA-5(6)	Параметр: authenticator_protection Тип: boolean Значення: true
55	Відсутність вбудованих незашифрованих статичних автентифікаторів	Бібліотека заохочує динамічну генерацію ключів під час ініціалізації середовища (Root CA), що виключає необхідність зберігання "hardcoded" секретів у вихідному коді системи.	IA-5(7)	Параметр: no_unencrypted_static Тип: boolean Значення: true
56	Багатосистемні облікові записи (mTLS/SSO)	Сертифікати X.509, видані 'sync/ca', можуть використовуватись як багатосистемний засіб автентифікації (на кшталт mTLS/SSO) для доступу до різноманітних мікросервісів та ERP-компонентів, розгорнутих у спільному домені довіри.	IA-5(8)	Параметр: multi_system_accounts Тип: boolean Значення: true
57	Управління об'єднанням автентифікаторів (Intermediate CA)	Підтримується архітектура федерації ключів (Federation) за рахунок використання ланцюгів сертифікатів (Intermediate CAs) та можливості перевіряти крос-сертифікаційні підписи (Cross-Certification).	IA-5(9)	Параметр: federation_management Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
58	Динамічне зв'язування мандатів	Бібліотека дозволяє видавати короткострокові сертифікати, що динамічно зв'язуються з конкретною сесією, IP-адресою чи атрибутами користувача (Dynamic Credential Binding).	IA-5(10)	Параметр: dynamic_credential_binding Тип: boolean Значення: true
59	Автентифікація на основі апаратних токенів	'synrc/ca' прозора підтримує роботу з підписами, згенерованими на апаратних захищених носіях (Hardware Tokens, HKI, e-Токени, PKCS#11). Серверній частині потрібен лише відкритий ключ для валідації.	IA-5(11)	Параметр: hardware_token_auth Тип: boolean Значення: true
60	Ефективність біометричної автентифікації (Secure Enclave)	Хоча 'ca' працює з криптографією, будь-яка біометрична автентифікація (наприклад, TouchID, FaceID) на клієнті конвертується в криптографічний підпис (наприклад, через Secure Enclave), який успішно валідується модулями 'synrc/ca'.	IA-5(12)	Параметр: biometric_efficiency Тип: boolean Значення: true
61	Закінчення терміну дії автентифікаторів (NotBefore/NotAfter)	Жорстко перевіряються поля 'NotBefore' та 'NotAfter' в сертифікатах X.509. Сертифікати зі строком дії, що минув, автоматично відхиляються без можливості оскарження.	IA-5(13)	Параметр: authenticator_expiration Тип: boolean Значення: true
62	Управління змістом довірчих сховищ (Trust Stores)	На рівні сервера бібліотека керує сховищем довірених кореневих сертифікатів (Trust Store, 'priv/cacerts'). Оновлення або відкликання (через CRL) довіри до Root CA автоматично реплікується на політику доступу.	IA-5(14)	Параметр: trust_store_management Тип: boolean Значення: true
63	Продукти та послуги, затверджені уповноваженим органом (ДСТУ 4145-2002)	Завдяки абстракції криптографічних примітивів, 'synrc/ca' підтримує державні криптографічні стандарти (наприклад, алгоритм цифрового підпису ДСТУ 4145-2002), необхідні для побудови систем, затверджених Державною службою спеціального зв'язку та захисту інформації (ДССЗІ).	IA-5(15)	Параметр: approved_products Тип: boolean Значення: true
64	Передача довірчої автентифікації зовнішньої сторони (АЦСК)	'synrc/ca' здатна перевіряти підписи, накладені зовнішніми Акредитованими центрами сертифікації ключів (АЦСК), забезпечуючи довірчу автентифікацію зовнішніх сторін.	IA-5(16)	Параметр: external_auth_transfer Тип: boolean Значення: true
65	Менеджер паролів (KeyStores)	Незважаючи на те, що 'synrc/ca' не є менеджером паролів у звичному розумінні, механізми захисту ключів (KeyStores, PKCS#12) виступають у ролі захищених криптографічних сейфів, які можна відкрити лише спеціалізованими засобами із дотриманням секретності.	IA-5(18)	Параметр: password_manager Тип: boolean Значення: true
3. АУДИТ ТА ПІДЗВІТНІСТЬ (AU) (AU)				
66	Узагальнення записів про аудит з декількох джерел (feeds)	BRMN підтримує паралельні ланцюги (feeds, streams), що дозволяє агрегувати записи про аудит з декількох джерел у єдиний потік журналу.	AU-2(1)	Параметр: audit_aggregation Тип: boolean Значення: true
67	Перегляд та оновлення (індексація hist)	Записи аудиту періодично індексуються, що дозволяє швидко витягувати всю історію (наприклад, через 'bpe:hist/1').	AU-2(3)	Параметр: audit_review_update Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
68	Зміст записів аудиту (метадані, Permit/Deny)	Інформація в логах BPMN (особливо при збереженні об'єктів ВРЕ/АВАС) містить вичерпні метадані: тип події, суб'єкт, цільовий об'єкт, результат операції (Permit/Deny) та позначку часу, що повністю закриває вимоги AU-3.	AU-3	Параметр: audit_content_metadata Тип: boolean Значення: true
69	Місткість сховища записів аудиту (розподілені бекенди)	BPMN може використовувати розподілені бекенди (Riak KV, розподілена Mnesia, KAI), що дозволяє горизонтально масштабувати місткість сховища логів (AU-4) без зупинки системи.	AU-4	Параметр: audit_storage_capacity Тип: boolean Значення: true
70	Позначка часу (erlang:system_time)	Усі ідентифікатори та події, що генеруються в BPMN (наприклад, через генератор 'id_seq'), прив'язані до високоточного системного часу Erlang ('erlang:system_time/1'). Це забезпечує надійну прив'язку подій до точного часу (AU-8(1)).	AU-8(1)	Параметр: sync_time_source Тип: boolean Значення: true
71	Апаратні носії одноразового запису (Append-Only)	Архітектура Append-Only гарантує, що записи не оновлюються (по UPDATE). Це створює ефект апаратного "Write-Once-Read-Many" (AU-9(1)). Видалити запис без порушення криптографічної чи логічної цілісності ланцюга посилань практично неможливо.	AU-9(1)	Параметр: append_only_enforced Тип: boolean Значення: true
72	Неспростовність (Ланцюжок збереження доказів)	Журнали BPMN слугують доказовою базою (Ланцюжок збереження доказів AU-10(3)). У комбінації з 'sync/ca' записи можуть підписуватися ЕЦП (AU-10(5)), що гарантує 100% неспростовність дій автора транзакції.	AU-10(3)	Параметр: non_repudiation Тип: boolean Значення: true
73	Довгострокова можливість отримання записів аудиту	Сховища типу RocksDB (в якості бекенда BPMN) оптимізовані для довгострокового зберігання петабайтів даних (Long-Term Storage) із забезпеченням швидкого доступу до історичних записів (AU-11(1)).	AU-11(1)	Параметр: log_retention_days Тип: integer Значення: 1825
74	Огляд, аналіз та звітність про аудит	Аналіз аудиту відбувається за допомогою консольних інструментів платформи (наприклад, 'kvs:hist/1' або інтерфейсів Erlang Shell). Також доступний експорт журналів для SIEM.	AU-6	Параметр: audit_analysis_tools Тип: boolean Значення: true
75	Генерація аудиту	KVS забезпечує генерацію записів аудиту для всіх операцій створення, оновлення (через створення нової ревізії) та видалення, гарантуючи фіксацію критичних подій безпеки.	AU-12	Параметр: audit_generation Тип: boolean Значення: true
4. ЦІЛІСНІСТЬ СИСТЕМИ ТА ІНФОРМАЦІЇ (SI) (SI)				
76	Перевірка вводу перевизначення (лише серверна валідація)	Клієнтська сторона (браузер) в 'sync/nitro' не містить логіки валідації, яку можна було б обійти чи перевизначити (override) через маніпуляції з DOM або JS. Уся перевірка жорстко зашита у виконуваний код Erlang ('sync/fgm'). Жодне клієнтське перевизначення не здатне змінити правила серверної валідації.	SI-10(1)	Параметр: server_side_validation_only Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
77	Перевірка вводу інформації помилок (екранування HTML)	Повідомлення про помилки валідації генеруються на сервері (Erlang) і передаються клієнту через WebSocket як готові безпечні HTML-фрагменти (екрановані 'nitro'), запобігаючи виникненню XSS під час відображення помилкового вводу користувачу.	SI-10(2)	Параметр: escape_html_output Тип: boolean Значення: true
78	Передбачувана поведінка (декларативні Records)	Оскільки валідація описана декларативно (Record-структурами з типами полів, як-от 'integer', 'string', 'date'), реакція системи на некоректні дані завжди є 100% передбачуваною (Predictable Behavior). Відсутні приховані клієнтські скрипти, що можуть реагувати непередбачувано на специфічний ввід.	SI-10(3)	Параметр: predictable_behavior Тип: boolean Значення: true
79	Часові взаємодії (таймаути N2O)	Оскільки ввід передається через сталий WebSocket-зв'язок (N2O), система має вбудований контроль тайм-аутів з'єднання та захист від перевантажень (Rate-limiting). Довгі запити або неповний ввід просто ігноруються після завершення вікна сесії, блокуючи атаки типу Slowloris.	SI-10(4)	Параметр: timing_interactions Тип: boolean Значення: true
80	Обмеження вводу довіреними джерелами і форматами	Бібліотека 'form' пропускає дані лише для тих полів, які явно задекларовані в схемі форми (Approved Formats). Pattern Matching платформи Erlang автоматично відкидає будь-які JSON/BERT payload-пакети, які містять незадекларовані поля (унеможлижуючи Mass Assignment Vulnerability) або походять з неавторизованого джерела (Trust Zone).	SI-10(5)	Параметр: strict_type_checking Тип: boolean Значення: true
81	Профілактика вводу даних (блокування через АВАС)	Комбінація 'nitro' та 'abac' дозволяє здійснювати профілактику (Prevention): якщо користувач не має права вносити дані в певне поле, це поле взагалі не рендериться на стороні клієнта або рендериться в стані 'readonly/disabled', а бекенд-валідатор автоматично блокує будь-яку спробу його програмно передати (Data Input Prevention at source).	SI-10(6)	Параметр: data_input_prevention Тип: boolean Значення: true
5. ЗАХИСТ НОСІЇВ ІНФОРМАЦІЇ (МР) (МР)				
82	Доступ до носіїв інформації (через Erlang VM)	Прямий доступ до файлів БД (RocksDB/Mnesia) на носіях закритий на рівні ОС. Весь логічний доступ здійснюється виключно через інтерфейс KVS всередині віртуальної машини Erlang, яка діє як обмежений шлюз доступу (MP-2(1)).	MP-2(1)	Параметр: os_level_access_control Тип: boolean Значення: true
83	Криптографічний захист носіїв (Data-at-Rest)	KVS підтримує політики постійного збереження даних на диск (Disk Persistence). Захист інформації в стані спокою (Data-at-Rest) реалізується через інтеграцію з шифруванням файлової системи (LUKS) або шифруванням значень (MP-4(1)).	MP-4(1)	Параметр: encryption_at_rest Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
84	Транспортування носіїв інформації (TLS-реплікація)	В розподіленому кластері KVS реплікує дані (переміщує їх) між нодами. Цей процес транспортування інформації захищається за допомогою TLS (Erlang Distribution over TLS), запобігаючи перехопленню даних поза контрольованими зонами (MP-5(1), MP-5(4)).	MP-5(1)	Параметр: tls_replication Тип: boolean Значення: true
85	Знищення інформації на носіях (Tombstones)	Хоча KVS є системою Append-Only, він надає чіткі API ('kvs:delete') для виконання процедур очищення даних (наприклад, для забезпечення вимог GDPR "Право на забуття"). Під час видалення запису, бекенд RocksDB гарантовано помічає блоки як видалені (Tombstones), які під час подальшої компресії фізично стираються з носія без можливості відновлення (MP-6(8)).	MP-6(8)	Параметр: tombstone_deletion_enabled Тип: boolean Значення: true
86	Використання носіїв інформації (марковані томи)	KVS може конфігуруватись на використання виключно заздалегідь визначених (іменованих) просторів таблиць на авторизованих томах зберігання, забороняючи використання невідомих чи немаркованих баз даних (MP-7(1)).	MP-7(1)	Параметр: authorized_volumes_only Тип: boolean Значення: true
6. ЗАХИСТ СИСТЕМ ТА КОМУНІКАЦІЙ (SC) (SC)				
87	Ізоляція функції безпеки	Функції безпеки (шифрування, авторизація) виконуються в ізольованих процесах Erlang VM, окремо від бізнес-логіки системи. Ця архітектура Actor Model унеможливорює втручання несанкціонованих процесів у роботу механізмів безпеки.	SC-2	Параметр: security_function_isolation Тип: boolean Значення: true
88	Інформація в загальних ресурсах системи	Erlang VM не використовує спільну пам'ять (shared memory) між процесами сесій N2O. Пам'ять звільняється автоматично (Garbage Collection) після обробки запиту, запобігаючи витоку залишкової інформації між різними користувачами.	SC-4	Параметр: shared_resource_protection Тип: boolean Значення: true
89	Захист від атак «відмова в обслуговуванні» (DoS)	Інфраструктура N2O/Cowboy обробляє сотні тисяч конкурентних WebSocket-з'єднань завдяки легкості Erlang-процесів. Вбудовані механізми rate-limiting, обмеження розміру payload та таймауту захищають від атак на виснаження ресурсів (Slowloris, Flood).	SC-5	Параметр: dos_protection Тип: boolean Значення: true
90	Захист периметра (Boundary Protection)	Всі зовнішні підключення приймаються виключно через єдиний порт (керований інтерфейс), що обробляється веб-сервером (Cowboy). Доступ до внутрішніх API і вузлів кластера блокується правилами мережевого екранування за замовчуванням (Default Deny).	SC-7	Параметр: boundary_protection Тип: boolean Значення: true
91	Захист цілісності та конфіденційності під час передачі	Передача інформації між клієнтом і сервером здійснюється виключно через зашифровані канали (WSS/TLS), що унеможливорює перехоплення (Man-in-the-Middle) або несанкціоновану модифікацію даних на льоту.	SC-8	Параметр: transmission_confidentiality Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
92	Розрив мережевого з'єднання	Протокол N2O автоматично розриває мережеве з'єднання після завершення комунікаційного сеансу або перевищення часу очікування (Inactivity Timeout), звільняючи ресурси та сесію.	SC-10	Параметр: network_disconnect_timeout Тип: integer Значення: 3600
93	Криптографічне управління ключами	Керування ключами та сертифікатами для встановлення захищених з'єднань делегується бібліотеці 'suncr/ca' та інтегрованим механізмам TLS OC, що відповідають чинним криптографічним стандартам.	SC-12	Параметр: cryptographic_key_management Тип: boolean Значення: true
94	Криптографічний захист	Система підтримує використання схвалених криптографічних алгоритмів (AES-GCM, SHA-256/512, ДСТУ 4145-2002 через відповідні модулі), які забезпечують необхідний рівень стійкості.	SC-13	Параметр: cryptographic_protection Тип: boolean Значення: true
95	Автентичність сеансу зв'язку	Автентичність WebSocket-сесій N2O захищається токенами з криптографічним підписом (HMAC). Це гарантує, що повідомлення в рамках сесії не можуть бути підроблені або інжектвані сторонньою особою.	SC-23	Параметр: session_authenticity Тип: boolean Значення: true
7. УПРАВЛІННЯ КОНФІГУРАЦІЄЮ (СМ) (СМ)				
96	Базова конфігурація (Baseline Configuration)	Файл 'eruno.ex' фіксує єдину базову конфігурацію (Baseline) безпеки для всієї системи. Зміни в конфігурації застосовуються виключно через оновлення коду, що забезпечує строгий контроль та аудит змін.	CM-2	Параметр: baseline_configuration_code Тип: boolean Значення: true
97	Контроль змін конфігурації	Оскільки CMDDB є частиною вихідного коду (Elixir модуль), всі зміни проходять через стандартний процес розробки (Code Review, CI/CD, контроль версій Git), унеможливаючи несанкціоноване втручання в налаштування на "живій" системі.	CM-3	Параметр: configuration_change_control Тип: boolean Значення: true
98	Налаштування конфігурації	Параметри політик безпеки та їхні значення за замовчуванням жорстко зашиті в 'eruno.ex'. Компілятор генерує незмінний об'єктний файл, який гарантує виконання затверджених налаштувань під час роботи.	CM-6	Параметр: compile_time_config Тип: boolean Значення: true
99	Інвентаризація компонентів ІТС	Профіль автоматично фіксує перелік використовуваних компонентів системи (бібліотеки 'suncr/kvs', 'suncr/ca' тощо) та їхні параметри, забезпечуючи інтегральну інвентаризацію модулів захисту.	CM-8	Параметр: component_inventory Тип: boolean Значення: true
100	План управління конфігурацією	Профіль 'ERPUNO.Profile' слугує самодокументованим планом управління конфігураціями, здатним автоматично генерувати актуальну документацію (через метод 'generate_md/0').	CM-9	Параметр: auto_generate_documentation Тип: boolean Значення: true
8. ПЛАНУВАННЯ БЕЗПЕРЕРВНОЇ РОБОТИ (СР) (СР)				
101	Резервне копіювання інформаційної системи	Система здійснює автоматичне створення резервних копій бази даних KVS. Бекапи можуть зберігатися локально або відправлятися до хмарних сховищ, гарантуючи відновлення даних відповідно до RTO/RPO.	CP-9	Параметр: system_backup Тип: boolean Значення: true

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
102	Відновлення інформаційної системи	KVS забезпечує механізми швидкого відновлення з резервних копій ('kvs:restore/1'), дозволяючи адміністраторам відновити працездатність вузла з гарантією логічної цілісності журналу транзакцій.	CP-10	Параметр: system_recovery Тип: boolean Значення: true
9. РЕАГУВАННЯ НА ІНЦИДЕНТИ (IR) (IR)				
103	Політика та процедури реагування на інциденти	Політика реагування на інциденти закріплена безпосередньо у бізнес-процесах (BPMN) 'eruno/itsm', забезпечуючи неухильне виконання процедур на кожному кроці життєвого циклу інциденту.	IR-1	Параметр: incident_policy_enforcement Тип: boolean Значення: true
104	Навчання з реагування на інциденти	Інтерфейс 'eruno/itsm' надає контекстні підказки та інструкції безпосередньо у формах обробки інцидентів, що виконує функцію інтерактивного навчання та підтримки персоналу в кризових ситуаціях.	IR-2	Параметр: incident_response_training Тип: boolean Значення: true
105	Тестування реагування на інциденти	Можливості BPE-движка дозволяють запускати симуляції інцидентів у тестовому середовищі 'itsm' для регулярного тестування планів реагування без впливу на продуктивну систему.	IR-3	Параметр: incident_testing_simulation Тип: boolean Значення: true
106	Обробка інцидентів	Будь-який інцидент безпеки автоматично реєструється як тикет у модулі 'itsm'. Процес обробки ('incident_management_process') гарантує, що інцидент пройде всі необхідні етапи: виявлення, ізоляція, усунення, відновлення.	IR-4	Параметр: incident_handling Тип: boolean Значення: true
107	Моніторинг інцидентів	Статуси інцидентів у реальному часі відображаються на дашбордах 'eruno/itsm'. BPE-движок дозволяє призначати SLA-таймауту (Boundary Events) для ескалації інцидентів, якщо час реакції перевищено.	IR-5	Параметр: incident_monitoring Тип: boolean Значення: true
108	Звітність про інциденти	Система 'eruno/itsm' автоматично формує звіти про інциденти, надаючи вичерпну інформацію про порушені сервіси, час простою (SLA) та дії команди, що закриває вимоги внутрішньої та зовнішньої звітності.	IR-6	Параметр: automated_incident_reporting Тип: boolean Значення: true
109	Допомога у реагуванні на інциденти	Вбудовані засоби комунікації в рамках тикету (коментарі, призначення експертів, інтеграція з базою знань) забезпечують оперативну допомогу та координацію групи безпеки під час інциденту.	IR-7	Параметр: incident_assistance Тип: boolean Значення: true
110	План реагування на інциденти	Сам конфігураційний код процесів 'eruno/itsm' виступає в ролі актуального та виконуваного плану реагування на інциденти (Executable Incident Response Plan), усуваючи розбіжність між документацією та реальністю.	IR-8	Параметр: executable_ir_plan Тип: boolean Значення: true
111	Реагування на витік інформації (Information Spillage)	Спеціалізовані BPMN-схеми в 'itsm' передбачені для обробки витоків інформації. Вони включають обов'язкові кроки ідентифікації скомпрометованих даних, блокування доступу ('abac') та сповіщення регулятора.	IR-9	Параметр: information_spillage_response Тип: boolean Значення: true
10. ОЦІНКА РИЗИКІВ (RA) (RA)				

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
112	Оцінка ризиків	Всі ідентифіковані вразливості або загрози фіксуються в реєстрі 'itsm', де їм присвоюється рівень критичності. На базі цього рівня розраховується пріоритет та призначаються відповідальні особи.	RA-3	Параметр: risk_assessment Тип: boolean Значення: true
113	Сканування вразливостей	Система передбачає можливість інтеграції зовнішніх сканерів вразливостей, звіти яких автоматично перетворюються на тикети усунення ризиків в системі 'itsm'.	RA-5	Параметр: vulnerability_scanning Тип: boolean Значення: true
11. ФІЗИЧНИЙ ЗАХИСТ ТА ЗАХИСТ НАВКОЛИШНЬОГО СЕРЕДОВИЩА (PE) (PE)				
114	Фізичний доступ	Регламентується інструкціями з режиму ЦОД (див. розділ PE у digital-profile.pdf).	PE-2	Параметр: physical_access_doc_ref Тип: string Значення: digital-profile.pdf
115	Контроль фізичного доступу	Регламентується системами СКУД будівлі (див. розділ PE у digital-profile.pdf).	PE-3	Параметр: physical_access_control_ref Тип: string Значення: digital-profile.pdf
12. ОБІЗНАНІСТЬ ТА НАВЧАННЯ (AT) (AT)				
116	Навчання з обізнаності щодо безпеки	Програми навчання та інструктажі (див. розділ AT у digital-profile.pdf).	AT-2	Параметр: security_awareness_training_ref Тип: string Значення: digital-profile.pdf
117	Навчання з питань безпеки, залежне від ролі	Спеціалізоване навчання для адміністраторів (див. розділ AT у digital-profile.pdf).	AT-3	Параметр: role_based_training_ref Тип: string Значення: digital-profile.pdf
13. УПРАВЛІННЯ РИЗИКАМИ В ЛАНЦЮГУ ПОСТАЧАННЯ (SR) (SR)				
118	План управління ризиками ланцюга постачання	План управління базується на принципі відмови від стороннього коду. Замість інтеграції сотень неперевіраних бібліотек, команда розробляє всі необхідні компоненти (веб-сервер N2O, KVS, CA) самостійно в єдиному монорепозіторії.	SR-2	Параметр: zero_dependency_policy Тип: boolean Значення: true
119	Контроль та захист ланцюга постачання	Заборонено використання автоматичних менеджерів пакетів для завантаження коду під час збірки. Весь вихідний код системи та модулів міститься безпосередньо в репозиторії проекту, що гарантує 100% контроль над кожним рядком коду, який компілюється.	SR-3	Параметр: strict_code_vendoring Тип: boolean Значення: true
120	Аудит та огляди постачальників	Єдиним зовнішнім «постачальником» є розробник платформи Erlang/OTP (компанія Ericsson та спільнота). Оновлення версій OTP проходять жорстку перевірку перед їх застосуванням на продуктивних серверах.	SR-6	Параметр: erlang_otp_supplier_review Тип: boolean Значення: true
121	Автентичність компонентів	Будь-які оновлення або патчі самої системи передаються виключно через захищені канали із застосуванням криптографічних підписів ('sync/ca'), що виключає можливість підміни бінарних файлів під час розгортання.	SR-11	Параметр: component_authenticity Тип: boolean Значення: true
14. ПЛАНУВАННЯ (PL) (PL)				

№	Вимога з безпеки інформації	Вимога ГПБ	ЦПБ	
			Захід захисту	Налаштований зміст заходу захисту
122	План безпеки системи	Система підтримує автоматичну генерацію актуального Плану безпеки системи на основі цього профілю (СМ). План чітко визначає всі технічні та організаційні контролю (АС, АУ, SC, СМ тощо), середовище функціонування та архітектуру.	PL-2	Параметр: system_security_plan Тип: boolean Значення: true
123	Правила поведінки	Для всіх користувачів платформи (організаційних та зовнішніх) визначаються правила поведінки. Згода з правилами (наприклад, Terms of Service, NDA) фіксується в базі даних KVS під час онбордингу, перед наданням доступу до ERP/1.	PL-4	Параметр: rules_of_behavior Тип: boolean Значення: true
124	Архітектура безпеки	Архітектура безпеки платформи (Actor Model, ізоляція процесів, Zero Dependencies, Append-Only логування) розробляється інтегровано з загальною архітектурою підприємства. Вона регулярно переглядається на відповідність державним стандартам (НД ТЗІ, NIST SP 800-53).	PL-8	Параметр: security_architecture Тип: boolean Значення: true